Secure Coding Quick Guide

SQL injection (CWE-89)

Never build SQL by string concatenation. Use parameterized queries and bind user input. Allow-list table and column names.

Cross-site scripting (CWE-79)

Encode output for its context. Use textContent instead of innerHTML. Prefer auto-escaping templates.

Password storage (CWE-916, CWE-328)

Do not use MD5 or SHA-1 for passwords. Use Argon2id, scrypt or bcrypt with a unique random salt. Never store plain-text passwords.

Hard-coded secrets (CWE-798)

Load API keys and passwords from environment variables or a secrets manager. Rotate any secret committed to source control.

Path traversal (CWE-22)

Resolve the canonical path and check that it stays inside the base directory. Reject absolute paths and parent segments.

Unsafe deserialization (CWE-502)

Never use pickle or native object deserialization on untrusted data. Use JSON with schema validation.

OS command injection (CWE-78)

Do not pass input to a shell. Use an argument list without shell=True and validate arguments against an allow-list.

Insecure randomness (CWE-330)

Use a cryptographically secure generator such as the Python secrets module for tokens and keys, never the random module.

TLS validation (CWE-295)

Never disable certificate verification. Keep verify enabled and fix the trust store instead.